

To: John Kasket, Governance Risk & Compliance Manager - Cyber Security

From: Christopher Contreras, Cybersecurity Policy Analyst

Date: April 23, 2025

Subject: Justification and Implementation Plan for Updated ACME Corporation Policies

Executive Summary

This memo describes the rationale for and recommends implementing modifications to ACME Corporation's Password Policy, Data Privacy Policy, and Cybersecurity Policy. These modifications are necessary to keep our organization up to date with current security standards, legal expectations, and general best practices in the field. Each policy update has been made with enforceability, user education, and incorporation into day-to-day activities in mind. For further detailed explanations, look at the Justification section on policies.

Justification for Policy Updates

Password Policy

Password security continues to be the first line of defense against unauthorized access. Our revised password policy represents essential updates, including:

- Increased complexity and expiration of passwords
- Requirements for system and administrator accounts
- Formal requirements for password managers and prohibitions on credential sharing

These updates adhere to portions of NIST SP 800-63B and ISO/IEC 27001 and enhance the importance of identity verification while reducing attack vectors created by weak credentials.

Data Privacy Policy

With continuously escalating regulatory scrutiny and consumer expectations, our updated data privacy policy includes the following:

- An employee consent clause to ensure transparency and accountability and support employee privacy.
- Data classification levels that govern protections based on sensitivity.
- Third-party vendor privacy oversight and data retention requirements.

These improvements reflect expectations from NIST SP 800-53 Rev. 5, ISO/IEC 27018, and NIST SP 800-92, which are an excellent starting point for managing privacy and applicable legal obligations.

Cybersecurity Policy

To address potential threats such as complacency, fragmented responses, and systems without regulation, significant changes include:

- Cloud security requirements and a requirement for Shadow IT management.
- A requirement for role-based access control and privileged account monitoring.
- Formal Incident Response Plan.

These changes are informed by best practices established from CIS Controls v8, NIST SP 800-61 Rev. 2, and real-life risk analysis reported by CISA and ENISA.

The department must stage and coordinate the process to implement the updated password, data privacy, and cybersecurity policies at ACME Corporation. The first step will be to internally distribute the revised policies via all staff email and the internal employee portal with executive validation from the Governance Risk & Compliance Manager, John Kasket. Acknowledging receipt of the policy must also be signed by staff to confirm they are aware. A 15–30-minute training session will be used to support staff understanding of the policy's intent, which will accompany each department's email/portal policy release method. This will also include an

interactive module for questions and answers and will be available asynchronously via the company LMS (Learning Management System).

Technical controls will also be implemented concurrently to support the continuance of staff-appropriate behaviors with the new policies. This will include monitoring of password manager usage for compliance, retention, and the logging timetable, updates to the logging and retention so that, at a minimum, they have 4-year data retention that can be audited by an external party, and configure any such 3rd party breeze monitoring or shadow IT detection systems to conduct their audits continuously. Access controls will be documented on a bi-annual schedule, and there will be alerts on unauthorized or related access control changes.

An internal compliance task force will be established to monitor the implementation of the three policy updates. This task force will coordinate and liaise with HR, IT, and Legal to support successfully scheduling audits, managing exceptions, and resolving potential issues for each policy.

References

Center for Internet Security. (2021). CIS Controls v8. <https://www.cisecurity.org/controls>

National Institute of Standards and Technology. (2017). Digital identity guidelines:

Authentication and lifecycle management (NIST SP 800-63B). <https://pages.nist.gov/800-63-3/sp800-63b.html>

National Institute of Standards and Technology. (2020). Security and privacy controls for information systems and organizations (NIST SP 800-53 Rev. 5).

<https://csrc.nist.gov/publications/detail/sp/800-53/rev-5/final>

National Institute of Standards and Technology. (2006). Guide to computer security log management (NIST SP 800-92). <https://csrc.nist.gov/publications/detail/sp/800-92/final>

International Organization for Standardization. (2022). ISO/IEC 27018: Protection of personally identifiable information (PII). <https://www.iso.org/standard/76559.html>

International Organization for Standardization. (2022). ISO/IEC 27001: Information security management systems. <https://www.iso.org/isoiec-27001-information-security.html>